

## Case Metadata

| Field        | Value                                  |
|--------------|----------------------------------------|
| Case ID:     | CS-2025-004                            |
| Case Type:   | Local File Inclusion Attack            |
| Reported by: | Splunk SIEM                            |
| Analyst:     | Ali YILMAZ                             |
| Date:        | 2025-10-05                             |
| Severity:    | Medium (High - escalate if successful) |
| Status:      | Closed                                 |
| Environment: | Production                             |

## Detection Rule Details

**Rule Name:** Local File Inclusion Attack

**Rule Description:** This Notable is looking for signatures of a directory traversal attack. A directory traversal attack exploits insufficient security validation or sanitization of user-supplied file names, such that characters representing "traverse to parent directory" are passed through to the operating system's file system API.

### **Correlation Rule (SPL):**

```
index=apache uri_query IN ("..", "/", "*etc*", "*passwd*")
```

### **Triggered Field(s):**

T1190 - Exploit Public-Facing Application

## Detection Summary

Access log shows a suspicious query parameter requesting local path via traversal: `http://fe80::250:56ff:feab:d44e/scripts/fake.cgi?arg=/dir/../../../../etc/passwd` — normalized to `/etc/passwd`. Source observed in event. Status: **404 (Not Found)**. Classified as **Potential LFI attempt — MITRE T1190**.

**Initial severity:** Medium (escalate to High if successful file read or 200 + sensitive content found).

## Analyst Investigation

- **Normalized path:** /etc/passwd (canonicalized from ?arg=/dir/../../../../../etc/passwd).
- **HTTP status:** 404 Not Found (no successful file retrieval recorded in access logs).
- **Response body / content indicators:** No evidence of root: or passwd contents in logs.
- **Activity pattern:** Single LFI attempt from the observed source in the captured window; no confirmed follow-up successful reads.
- **MITRE mapping:** T1190 — Exploit Public-Facing Application (LFI / path traversal). Possible follow-on technique if successful: T1083 File and Directory Discovery.

**Assessment:** Attempt detected and canonicalized; **no evidence of successful data exfiltration** in logs — classify as **Attempted LFI (Unsuccessful)**. Mark as **False Positive for successful compromise**, but **True Positive** as an attack attempt.

### Investigation Steps:

1. Extracted arg parameter from uri\_query in Splunk (raw event).  
SPL used:
2. index=apache uri\_query="\*arg=\*etc/passwd\*"
3. | rex field=uri\_query "arg=(?<arg>.\*)\$"
4. | eval arg\_decoded=urldecode(arg)
5. Canonicalized path to detect traversal (/dir/../../../../../etc/passwd → /etc/passwd).  
Tools used: posixpath.normpath (Python) locally and a chained replace() approach in SPL for verification. Result stored as norm = /etc/passwd.
6. Checked HTTP status and response indicators in access logs: status=404, no evidence in logs of file contents (no root: token found).  
SPL used for content/status pivot:
7. index=apache (uri\_query="\*etc/passwd\*" OR uri="\*/etc/passwd\*")
8. | table \_time client src dest uri uri\_query status http\_user\_agent response\_time
9. Pivoted on source IP/client for additional activity and fuzzing patterns (same source rapid requests / multiple paths).  
SPL used:
10. index=apache client=10.1.1.72 OR src=10.1.1.72

11. | bin \_time span=1m
12. | stats count dc(uri) as uniq\_uris values(uri\_query) as queries by \_time
13. | where count>5
14. Checked WAF/IDS alerts and server error logs (if available) for successful includes or webshell errors

## MITRE ATT&CK Mapping

T1190 - Exploit Public-Facing Application

✅ True Positive (Attempted LFI Attack) Not Successful (no data exfiltration / no impact)

## Recommended Actions

- Temporarily block source IP/client at perimeter/WAF for hunting window (or add to WAF rules for rate limiting).
- Continue monitoring for additional LFI attempts from same source or / similar payloads.
- Search for any events with status=200 for the same URI/payload or with response bodies containing root:/root:x:. Escalate immediately if found.
- Add detection rule to correlate uri\_query containing traversal patterns (., %2e%2e, php://) and alert when status=200 or response contains sensitive tokens.

## Organizational / HR Actions

- No user credentials implicated. No HR action required at this stage.
- Inform application owners / Dev team: provide example payload and recommend code review of fake.cgi endpoint and input handling. Add to backlog for secure coding remediation.

## Business Impact

- **Current impact:** Low — attempted access only, no confirmed data exposure.
- **Potential impact if successful:** High — access to /etc/passwd may reveal system accounts; further successful reads could escalate to info disclosure and compromise.

## Evidence in Case

- Raw Splunk event (access\_log) — include screenshot and raw \_raw event export.
- Canonicalization evidence: arg = /dir/../../../../etc/passwd → norm = /etc/passwd (Python posixpath.normpath output / Splunk norm field).
- Splunk queries and results used for triage (paste SPL snippets above).
- Timestamp and source fields saved in the case (attach screenshot from Splunk).

Incident Review

Search...Show ChartsHide Filters

Save filters: Select...Add tags...Urgency: Select...Status: Select...Owner: Select...Security Domain: Select...Type: Select...Search Type: Correlation S...Select...Time or Associations: Associations

Associations: Short ID: KYVUJF (1)Save new filtersUpdateClear allSubmitAssociations: Short ID: KYVUJF x

1 NotablesUnselect all | Edit Selected | Edit All Matching Events (1) | Add Selected to Investigation20 per pageRefresh

| <input checked="" type="checkbox"/> | <input type="checkbox"/> | Title                       | Risk Object | Risk Score | Risk Events | Type    | Time                     | Disposition | Security Domain | Urgency | Status | Owner          | Actions |
|-------------------------------------|--------------------------|-----------------------------|-------------|------------|-------------|---------|--------------------------|-------------|-----------------|---------|--------|----------------|---------|
| <input checked="" type="checkbox"/> | <input type="checkbox"/> | Local File Inclusion Attack | --          | --         | --          | Notable | Thu, Oct 2, 2025 2:00 AM | Other       | Threat          | Low     | New    | Arezoo Ghobadi |         |

Description:

This Notable is looking for signatures of a directory traversal attack. A directory traversal attack exploits insufficient security validation or sanitization of user-supplied file names, such that characters representing "traverse to parent directory" are passed through to the operating system's file system API.

Additional Fields

Value

Action

|                        |                                                                                  |  |
|------------------------|----------------------------------------------------------------------------------|--|
| Action                 | Not Found                                                                        |  |
| Bytes In               | 356                                                                              |  |
| Bytes Out              | 450                                                                              |  |
| Destination            | fe80::250:56ff:feab:d44e                                                         |  |
| Destination Port       | 80                                                                               |  |
| HTTP Method            | GET                                                                              |  |
| HTTP User Agent        | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)                  |  |
| Host                   | splunk-proxy-08                                                                  |  |
| Original Splunk Source | /var/log/httpd/access_log                                                        |  |
| Product                | Web Server                                                                       |  |
| Risk Score             | 960                                                                              |  |
| Severity               | high                                                                             |  |
| Source                 | 10.1.1.72                                                                        |  |
| URL                    | http://fe80::250:56ff:feab:d44e/scripts/fake.cgi?arg=/dir/../../../../etc/passwd |  |
| Vendor                 | Apache                                                                           |  |
| Vendor/Product         | Apache Web Server                                                                |  |

Related Investigations:

Currently not investigated.

Correlation Search:

Threat - Local File Inclusion Attack - Rule

History:

2025 Oct 2 8:00:22 PMEmre Tunca

< Previous

View all review activity for this Notable Event

Contributing Events:

go-to-logs

Original Event:

time=1759381772.599231, bytes\_in=356, bytes\_out=450, cookie="-", server=fe80::250:56ff:feab:d44e, dest\_port=80, http\_content\_type="", http\_method="GET", http\_referer="", http\_user\_agent="Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)", ident="-", response\_time\_microseconds=273, client=10.1.1.72, status=404, uri\_path="/scripts/fake.cgi", uri\_query="?arg=/dir/../../../../etc/passwd", user="-"

View original event

Adaptive Responses:

| Response | Mode  | Time                     | User  | Status  |
|----------|-------|--------------------------|-------|---------|
| Notable  | saved | 2025-10-02T02:00:07-0400 | admin | success |

View Adaptive Response Invocations

Next Steps:

No next steps defined.

Event Details:

|            |                                                                             |
|------------|-----------------------------------------------------------------------------|
| event_id   | FC5EF1EF-0E6E-4C54-902C-4CB2803883E5@notable@44fd389c3971e36dee6cb1a4737da2 |
| event_hash | 44fd389c3971e36dee6cb1a4737da2                                              |
| eventtype  | modnotable_results                                                          |
| notable    | notable                                                                     |
| Short ID   | KYVUJF                                                                      |

splunkenterpriseAppsAll Yilmaz998 MessagesSettingsActivityHelpFindSecurity PostureIncident ReviewInvestigationsSecurity IntelligenceSecurity DomainsCloud SecurityAuditSearchConfigureEnterprise Security

New Search

Save AsCreate Table ViewClose

index=apache (uri\_query="etc/passwd" OR uri="\*/etc/passwd") | table \_time client src dest uri uri\_query status http\_user\_agent response\_time

Date time range

6 events (10/2/25 1:00:00.000 AM to 10/2/25 2:00:00.000 AM)No Event SamplingJob || || | Smart Mode

EventsPatternsStatistics (6)Visualization

20 Per Page Page Format Preview

| _time                   | client    | src       | dest                     | uri | uri_query                                        | status | http_user_agent                                                 | response_time |
|-------------------------|-----------|-----------|--------------------------|-----|--------------------------------------------------|--------|-----------------------------------------------------------------|---------------|
| 2025-10-02 01:09:35.819 | 10.1.1.72 | 10.1.1.72 | fe80::250:56ff:feab:d44e |     | ?lang=../../../../../../../../etc/passwd%00      | 404    | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0) | 0.43          |
| 2025-10-02 01:09:32.603 | 10.1.1.72 | 10.1.1.72 | fe80::250:56ff:feab:d44e |     | ?arg=/dir/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd | 404    | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0) | 0.29          |
| 2025-10-02 01:09:32.599 | 10.1.1.72 | 10.1.1.72 | fe80::250:56ff:feab:d44e |     | ?arg=/dir/../../../../../../../../etc/passwd     | 404    | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0) | 0.27          |
| 2025-10-02 01:15:45.090 | 10.1.1.72 | 10.1.1.72 | fe80::250:56ff:feab:d44e |     | ?toc=/etc/passwd%00                              | 404    | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0) | 0.28          |
| 2025-10-02 01:15:44.828 | 10.1.1.72 | 10.1.1.72 | fe80::250:56ff:feab:d44e |     | ?LD=../../../../../../../../etc/passwd           | 404    | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0) | 0.23          |
| 2025-10-02 01:15:44.790 | 10.1.1.72 | 10.1.1.72 | fe80::250:56ff:feab:d44e |     | ?NS-query-pat=../../../../../../../../etc/passwd | 404    | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0) | 0.23          |

spunk-enterpriseApps

All Yilmaz998 MessagesSettingsActivityHelpFind

Security PostureIncident ReviewInvestigationsSecurity IntelligenceSecurity DomainsCloud SecurityAuditSearchConfigureEnterprise Security

New Search

Save AsCreate Table ViewClose

Index=apache url\_query="target=dir/../../../../../../../../etc/passwd"

Date time range

1 event (10/2/25 10:00:00.000 AM to 10/2/25 2:00:00.000 AM)No Event SamplingJobFormatSmart Mode

Events (1)PatternsStatisticsVisualization

Format TimelineZoom OutZoom to SelectionDeselect1 minute per column

ListFormat20 Per Page

< Hide Fields

All Fields

SELECTED FIELDS

# host 1

# source 1

# sourcetype 1

# action 1

# arg 1

# bytes 1

# bytes\_in 1

# bytes\_out 1

# client 1

# cookie 1

# date\_hour 1

# date\_minute 1

# date\_second 1

# date\_wday 1

# date\_year 1

# date\_zone 1

# dest 1

# dest\_port 1

# eventtype 3

# http\_method 1

# http\_user\_agent 1

# http\_user\_agent\_length 1

# index 1

# linecount 1

# product 1

# punct 1

# response\_time 1

# response\_time\_microseconds 1

# server 1

# splunk\_server 1

# src 1

# status 1

# status\_description 1

# status\_type 1

# tag 1

# tag:eventtype 1

# time 1

# timeendpos 1

# timostartpos 1

# url\_path 1

# url\_query 1

# url 1

# url\_length 1

# vendor 1

# vendor\_product 1

+ Extract New Fields

Time

10/2/25

10:09:32.599 AM

Event

Time=1759381772.599231, bytes\_in=356, bytes\_out=450, cookie="-", server=fe80::250:56ff:feab:d44e, dest\_port=80, http\_content\_type="-", http\_method="GET", http\_referer="-", http\_user\_agent="Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)", ident="-", response\_time\_microseconds=273, client=10.1.1.72, status=404, uri\_path="/scripts/fake.cgi", url\_query="target=dir/../../../../../../../../etc/passwd", user="-"

Event Actions

TypeFieldValueActions

Selected

host

spunk-proxy-ol8

source

/var/log/httpd/access\_log

sourcetype

apache.access.log

Event

action

Not Found

arg

/dir/../../../../../../../../etc/passwd

bytes

806

bytes\_in

356

bytes\_out

450

client

10.1.1.72

cookie

-

dest

fe80::250:56ff:feab:d44e

dest\_port

80

eventtype

access\_log\_event (web)

http\_method

GET

http\_user\_agent

Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)

http\_user\_agent\_length

63

product

Web Server

response\_time

0.27

response\_time\_microseconds

273

server

fe80::250:56ff:feab:d44e

src

10.1.1.72

status

404

status\_description

Not Found

status\_type

Client Error

tag

web

time

1759381772.599231

url\_path

/scripts/fake.cgi

url\_query

target=dir/../../../../../../../../etc/passwd

url

http://fe80::250:56ff:feab:d44e/scripts/fake.cgi?target=dir/../../../../../../../../etc/passwd

url\_length

86

vendor

Apache

vendor\_product

Apache Web Server

Time

\_time

2025-10-02T01:09:32.599-04:00

Default

index

apache

linecount

1

punct

==\_=\_=\_=\_=\_=\_=\_=\_=\_=\_=\_=\_=\_=\_=\_=\_=\_=\_=\_=\_={

splunk\_server

splunk-prod

Filter by title

<configuration>

> <administrators>

> <administratorsProviders>

> <configPaths>

> <configurationRedirection>

> <moduleProviders>

> <modules>

> <system.applicationHost>

> <system.ftpServer>

> <system.webServer>

> <system.webServer>

> <asp>

> <caching>

> <cgi>

> <defaultDocument>

> <directoryBrowse>

> <fastCgi>

> <globalModules>

> <handlers>

> <httpCompression>

Download PDF

## CGI <cgi>

03/23/2022

### Overview

The `<cgi>` element configures default settings for Common Gateway Interface (CGI) applications for Internet Information Services (IIS) 7. These settings define the environment that IIS 7 will use when launching CGI processes. For example, the `createCGIWithNewConsole` and `createProcessAsUser` attributes specify how IIS 7 will launch a CGI application, and the `timeout` attribute specifies how long IIS will let a CGI application run before terminating the process.

CGI is sometimes considered to be a legacy application environment. Because of the processing overhead that is associated with launching CGI applications as separate processes, technologies like HTTP Modules, ISAPI extensions, ASP/ASP.NET, and FastCGI are preferred over CGI for application development.

#### Note

The CGI environment is not installed by default; however, installing the CGI environment also installs the necessary functionality for using FastCGI applications. For more information about using FastCGI on IIS 7, see the `<fastCgi>` element.

#### In this article

##### Overview

- Compatibility
- Setup
- How To
- Configuration
- Sample Code

Was this page helpful?

Yes No

## TECHNIQUES

## Exploit Public-Facing Application

## External Remote Services

## Hardware Additions

## Phishing

## Replication Through Removable Media

## Supply Chain Compromise

## Trusted Relationship

## Valid Accounts

## Wi-Fi Networks

## Execution

## Persistence

## Privilege Escalation

[Home](#) > [Techniques](#) > [Enterprise](#) > [Exploit Public-Facing Application](#)

## Exploit Public-Facing Application

Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network. The weakness in the system can be a software bug, a temporary glitch, or a misconfiguration.

Exploited applications are often websites/web servers, but can also include databases (like SQL), standard services (like SMB or SSH), network device administration and management protocols (like SNMP and Smart Install), and any other system with Internet-accessible open sockets.<sup>[1][2][3][4][5]</sup> On ESXi infrastructure, adversaries may exploit exposed OpenSLP services; they may alternatively exploit exposed VMware vCenter servers.<sup>[6][7]</sup> Depending on the flaw being exploited, this may also involve Exploitation for Defense Evasion or Exploitation for Client Execution.

If an application is hosted on cloud-based infrastructure and/or is containerized, then exploiting it may lead to compromise of the underlying instance or container. This can allow an adversary a path to access the cloud or container APIs (e.g., via the [Cloud Instance Metadata API](#)), exploit container host access via [Escape to Host](#), or take advantage of weak identity and access management policies.

ID: T1190

Sub-techniques: No sub-techniques

① **Tactic:** [Initial Access](#)① **Platforms:** Containers, ESXi, IaaS, Linux, Network Devices, Windows, macOS**Contributors:** Praetorian; Yossi Weizman, Azure Defender Research Team**Version:** 2.7**Created:** 18 April 2018**Last Modified:** 15 April 2025[Version](#) [Permalink](#)